📝 令和5年春 应用情報 午後問1【情報セキュリティ】小南解题

> 📌 **AP 午後考点速攻** | 核心覆盖：**Cyber Kill Chain 阶段判定、EDR 终端行为监控、CSIRT 应急响应组织、SIEM 日志集中相关分析、离线备份（Offline Air-gap）**。

📑 一、整体背景梳理

🏢 业务背景与事故爆发（インシデント発生）

- **企业概况**：**R社**（约 150 名员工的旅行社，处理大量客户个人信息，属于个人情报取扱事業者）。
- **事故经过**：
  - 员工 S 收到伪装成交易先的邮件，打开附件后导致电脑（PC-S）感染勒索软件（Ransomware），文档被加密。
  - 因不知道联系窗口，S 延迟数小时后才联系上司，并在指示下报告 IT 部门。
- **应急初动**：IT 部门的 T 先生接到报告后，立即指示将 PC-S **切断网络（物理/逻辑断网）** 并回收设备。

🔍 安全支援厂商（Z社）调查与 Kill Chain 评估

根据 Cyber Kill Chain 评估，本次攻击的进展如下：

- 📧 **1~3. 侦察 / 武器化 / 交付**：发送伪装邮件。
- ⚠️ **4. 漏洞利用（Exploit）**：员工打开附件运行。
- 💻 **5. 安装（Installation）**：勒索软件安装成功并加密文件。
- 🛑 **6~7. C&C 通信 / 目的执行**：未发现外网 C&C 通信及内网 IP 扫描痕迹。
  👉 **结论**：攻击停留于 **第 5 阶段（インストール / Installation）**。

⚠️ 暴露的 5 大安全管理课题与改善案（表2 & 表3）

项番	暴露的课题 PDF	对应改善案（表3）PDF	核心解决手段
1️⃣	无法实时感知勒索软件运行	项番 1：监控终端异常行为	引入 **EDR**（终端行为监控）

2️⃣	缺乏事故预兆捕捉机制	项番 2：集中分析多设备日志	引入 **SIEM**（日志集约相关分析）
3️⃣	缺乏事故应急响应流程	项番 5：明文化应对体制与步骤	建立 **CSIRT** 并编写手册
4️⃣	应急流程未在员工中普及	项番 7：定型化应急响应演练	开展全员 **通报/检知训练**
5️⃣	针对钓鱼邮件的对策未周知	项番 8：针对性安全教育	开展 **靶向邮件防护教育**

🎯 二、逐题深度解析

❓ 設問 1：初动应对与杀伤链阶段判定

(1) 下划线 ①：对 PC-S 应当立即采取的措施

- 🟢 **参考答案：ウ（ネットワークから切り離す）**
- 🔍 **逻辑拆解：**
  - **目的**：防止勒索软件向内网其他机器横向扩展（Lateral Movement），或与外网 C&C 服务器建立连接。
  - ❌ 乱删文件或关闭业务应用无法阻止后台恶意进程，反而可能破坏调查证据。

(2) 空栏 a：Cyber Kill Chain 已经完成的阶段

- 🟢 **参考答案：5**
- 🔍 **逻辑拆解：**
  - 调查显示，恶意软件已成功安装在 PC-S 上（Stage 5），但没有产生连接 C&C 服务器（Stage 6）的痕迹。因此已完成的攻击阶段止步于 **5**。

❓ 設問 2：EDR 概念与管理课题对应

(1) 表2项番3 对应的表3改善案编号

- 🟢 **参考答案：5**
- 🔍 **逻辑拆解：**

- 表2项番3 指出“未整備インシデント発生時の対応手順（未建立事故处理流程）”。
- 对应表3项番5“インシデント発生時の対応体制や手順を検討して明文化する（梳理并明文化体制与步骤）”。

(2) 下划线 ②：监控终端异常行为的机制缩写

- 🟢 **参考答案：イ（EDR）**
- 🔍 **逻辑拆解：**

> 💡 **小南知识库：EDR vs 传统杀毒软件**
>
> - **传统杀软**：基于特征码匹配（Pattern Matching），对未知的 Zero-day 勒索软件防范力较弱。
> - **EDR（Endpoint Detection and Response）**：部署在终端上，实时监控**异常行为（Behavior Monitoring）**，即使是未知恶意软件也能快速隔离处置。

❓ 設問 3：CSIRT、资产/脆弱性关联及技术调查内容

(1) 下划线 ③：应急响应组织的缩写

- 🟢 **参考答案：イ（CSIRT）**
- 🔍 **逻辑拆解：**
  - **CSIRT（Computer Security Incident Response Team）** 是专门负责监控、收集安全事故信息并统一指挥处置的组织。

(2) 空栏 b、c、d 填充表3项番

- 🟢 **参考答案：**
  - **b：3**
  - **c：6**
  - **d：5**
- 🔍 **逻辑拆解：**
  - **b & c**：表4项番3“把握 R 社使用的设备并收集关联脆弱性信息”。对应表3的 **3**（更新资产台账）与 **6**（建立脆弱性信息收集方法）。

- **d**：表4项番4“整理并文档化社内外联络体制”。对应表3的 **5**（明文化应对体制与步骤）。

(3) 下划线 ④：技术性对策改善需调查的内容

- 🟢 **参考答案：ア（使用された攻撃手法）、ウ（被害を受けたシステムの脆弱性の情報）**
- 🔍 **逻辑拆解：**
  - **核心点**：题目要求针对技术性对策（技術的な対策）进行改善。
  - 能够直接指导技术加固的只有**攻击手法（ア）与系统脆弱性（ウ）**。损失金额（イ）或行业类型（エ）对技术修补没有直接参考价值。

❓ 設問 4：全员演练阶段与离线备份保管

(1) 下划线 ⑤：全员参与的演练阶段

- 🟢 **参考答案：ア（検知/通報(受付)）**
- 🔍 **逻辑拆解：**
  - 发生事故时，**所有员工**都可能是第一发现者（如看到勒索弹窗）。全员都必须熟练掌握“如何第一时间向 CSIRT 通报”。
  - 后续的分流（Triage）、处置（Response）、外宣（Release）属于专业 CSIRT 或管理层的职能。

(2) 下划线 ⑥：备份介质的正确保管方法（20字以内）

- 🟢 **参考答案：PCから切り離して保管する**（13字）
- 🔍 **逻辑拆解：**
  - 🚨 **勒索软件防范铁律（Air-gap / 离线备份）：**
    如果备份移动硬盘或网盘一直与 PC 保持连接，PC 感染勒索软件时，备份盘也会同时被加密，失去恢复作用。因此备份完成后必须**与 PC 物理断开连接进行保管**。

📊 三、核心考点速查

考察维度	考点核心	原理要点

🛡️ **终端安全防护**	**EDR (Behavior Monitoring)**	补充传统特征码杀软不足，通过监控**终端异常行为**及时发现和阻断未知勒索软件。
🚨 **应急初动处置**	**物理/逻辑断网 (Isolation)**	发现感染征兆时，首要动作是**切断网络**（拔网线/断 Wi-Fi），防止横向扩散与 C&C 通信。
🏛️ **应急响应体制**	**CSIRT & 全员通报**	**CSIRT** 负责事故统一处置；**全员训练**聚焦于事故的**感知与第一时间通报（検知/通報）**。
💾 **灾备防护对策**	**离线备份 (Offline Air-gap)**	备份介质在备份完成后必须**从 PC 断开（PCから切り離す）**，防止备份文件同步被勒索软件加密。